REPORT TECNICO-STRATEGICO: OPERAZIONE "NORTHSTAR FALL"

Documento di Simulazione APT (Advanced Persistent Threat)

Target: NATO – NCIA (Communications and Information Agency)

Analista: Corrado Vaccarecci

---

1. Strategia OSINT: Caccia alla "Vulnerabilità Umana"

L'indagine preliminare non mira a falle software, ma a individui con privilegi elevati. Tramite **LinkedIn Sales Navigator** e i metadati dei PDF ufficiali sul sito nato.int, identifichiamo un **Network Administrator Tier-3**. Il bersaglio è scelto per il suo potere d'accesso e per l'isolamento gerarchico: un "capo" riceve ordini che i sottoposti non vedono, annullando la difesa collettiva.

2. Il "Pretexting" (La mail di avviso): Perché l'anticipo?

L'attacco non è improvviso. Viene inviata una mail informativa il **6 maggio**, tre giorni prima dell'attacco. Questo serve a programmare il cervello della vittima: quando arriverà la mail malevola, non sarà un evento sospetto, ma la "conferma" di qualcosa di già annunciato. Si sfrutta il principio di **Impegno e Coerenza** di Cialdini.

[Email 1] All'Amministratore Target (06/05 - Ore 10:00)

Oggetto: AVVISO TECNICO: Aggiornamento Protocolli di Cifratura Operativa (AEP-67)

"All'attenzione del Responsabile Tecnico Tier-3,

A seguito dell'audit di sicurezza Q1-2026, il comando NCIA ha programmato il re-keying dei certificati sulla dorsale di rete **NorthStar** per il giorno giovedì 09/04.

Alle ore 11:30 CET di giovedì, riceverà una notifica automatica con le istruzioni per la riconvalida obbligatoria del suo profilo amministrativo. La procedura è necessaria per garantire la sincronizzazione dei gateway di sicurezza con i nuovi standard AEP-67.

Data la natura sensibile dell'intervento, si prega di mantenere la massima riservatezza e di non coinvolgere il personale operativo non autorizzato.

NCIA | Cyber Security Operations Centre (CSOC)"

3. Consolidamento del Pretesto: La Mail al Service Desk

Per blindare l'inganno, inviamo una mail anche all'**Help Desk IT**. Informandoli di una "manutenzione programmata", trasformiamo l'ufficio tecnico in un complice ignaro. Se il responsabile tecnico chiedesse conferma a un collega, riceverebbe un "sì" convinto, chiudendo la vittima in una bolla di falsa realtà.

[Email 2] All'Help Desk IT (06/05 - Ore 09:15)

Oggetto: [INFO] Finestra di manutenzione "NorthStar" - Supporto Livello Tier-3

"Gentile Team Help Desk, si informa che è prevista una finestra di intervento tecnico per il giorno **09/05, dalle ore 11:00 alle ore 13:00 CET**.

L'operazione riguarderà esclusivamente il personale con privilegi **Tier-3**. In caso di chiamate di verifica, si prega di confermare la legittimità della finestra di manutenzione. Non è richiesta l'apertura di ticket interni. Il personale Tier-3 farà riferimento esclusivamente al numero di supporto rapido NCIA fornito nelle comunicazioni riservate (+32 3331234567).

NCIA | Infrastructure & Services Ops"

4. Il "Whaling" e l'Isolamento del Potere

Mirando ai vertici, sfruttiamo il "silo informativo". La clausola di riservatezza impedisce che il sospetto si diffonda. Il responsabile tecnico non condivide l'informazione con i sottoposti per gerarchia e protocollo, facilitando l'attacco mirato.

5. L'Angolo di Attacco: Autorità e Urgenza Pianificata

La mail finale (9 maggio, ore 11:30) usa il principio di **Autorità** e un'**Urgenza Scadenzata** (15 minuti). Lo stress temporale inibisce il pensiero critico.

[Email 3] Al responsabile tecnico - L'Attacco Effettivo (09/05 - Ore 11:30)

Oggetto: URGENTE: Validazione Sessione Amministrativa [Ref: NATO-7721-B]

"Come da comunicazione del 06/04, la migrazione dei protocolli NorthStar è stata avviata. Per prevenire il de-sync dei gateway e la revoca automatica dei permessi, è necessario completare la riconvalida del suo profilo Tier-3 entro i prossimi **15 minuti**.

Acceda al portale tecnico NCIA tramite il link sicuro sottostante: **https://ncia.nato-int.org/ops/auth/verify-token-7721**

In caso di errori o per supporto vocale crittografato, contatti il supporto rapido: **+32 333 1234567** (Int. 102).

NCIA - Leading NATO's Digital Endeavour"

6. Il Sito Civetta: "NATO Trusted Gateway"

Registriamo un dominio tramite **Typosquatting** (ncia.nato-int.org) con certificato **SSL**. Il "lucchetto verde" fornisce una falsa sicurezza tecnica.

7. Cloning e "Cognitive Mirroring"

Cloniamo il sito ufficiale NCIA. L'admin ritrova gli stessi font e loghi. Questo "Mirroring" induce il cervello in modalità automatica, abbassando le difese analitiche.

8. Manipolazione dei Contatti e Vishing

Sostituiamo i contatti nella pagina "Contact Us" del sito clone con un numero **VoIP** controllato da noi. Fornire un numero di telefono trasmette legittimità.

9. Lo Scenario di "Verifica" al Telefono

Se il responsabile tecnico chiama, risponde un operatore che usa il gergo militare corretto. *"Sì, Colonnello, stiamo vedendo il de-sync, proceda pure sul portale"*. È la conferma definitiva.

10. Accesso Iniziale tramite AiTM (Adversary-in-the-Middle)

Il link porta a un portale di phishing avanzato (es. **Evilginx2**). Intercettiamo il traffico tra la vittima e la vera NATO, catturando il **Cookie di Sessione** e bypassando totalmente l'MFA.

11. Esfiltrazione Silenziosa: DNS Tunneling

Usiamo il **DNS Tunneling** (porta 53). Per i firewall della NATO, sembrerà normale traffico di risoluzione nomi, rendendo il furto invisibile.

12. Persistenza "Fileless" e Mimetismo

Usiamo tecniche **Fileless** come il **Process Hollowing**: iniettiamo codice in processi sicuri (es. explorer.exe). Usiamo il **"Living off the Land"** (PowerShell) per confonderci con l'attività quotidiana.

13. Invisibilità: Log Wiping e Anti-Forensics

Effettuiamo una **pulizia selettiva** dei log di sistema. Applichiamo il **Timestomping** per retrodatare i nostri script, rendendoli invisibili a qualsiasi analisi forense.

RIEPILOGO OPERATIVO: TIMELINE E ANALISI PSICOLOGICA

TIMELINE DEGLI AVVENIMENTI

01/05 - 05/05: Preparazione infrastruttura (Dominio, Sito Clone, Server AiTM, Numero VoIP).

06/05 09:15: Invio **[Email 2]** all'Help Desk IT (Corroborazione).

06/05 10:00: Invio **[Email 1]** all'Admin (Pre-texting/Adescamento).

09/05 11:30: Invio **[Email 3]** (Email d'Attacco) con link malevolo.

09/05 11:35: Finestra di **Vishing** (Supporto telefonico per validare l'inganno).

09/05 12:00: Exploitation (Cattura Cookie) e setup persistenza.

09/05 - 10/05: Esfiltrazione silenziosa dei dati e pulizia tracce (Anti-Forensics).

APPENDICE: I 5 PILASTRI DI CIALDINI UTILIZZATI

Impegno e Coerenza: L'invio della mail informativa lunedì "aggancia" la vittima; giovedì agirà per coerenza con l'informazione ricevuta.

Autorità: Uso di loghi, termini militari (AEP-67) e un tono istituzionale impeccabile per indurre obbedienza.

Riprova Sociale: L'Help Desk (ingannato) conferma l'operazione, fornendo alla vittima la validazione del gruppo.

Scarsità / Urgenza: Il countdown di 15 minuti sposta la decisione dal pensiero analitico a quello istintivo.

Simpatia / Somiglianza: Il sito clonato replica l'ambiente familiare dell'utente, eliminando l'attrito del sospetto.

Conclusione: L'operazione "NorthStar Fall" dimostra che la manipolazione del contesto informativo è l'arma più efficace contro le difese tecnologiche. Attraverso un ecosistema di fiducia (Email, Help Desk, Sito, Vishing), l'attaccante diventa indistinguibile dall'autorità legittima.